CAPACITACIÓN TÉCNICA · BANCO DE MÉXICO

Módulo 3. A03

Cadena de Suministro



Desarrollo Seguro de Sistemas (OWASP) · Banco de México
Java JDK 17 · Jakarta EE 11 · PostgreSQL 16

50 diapositivas · A03:2025 y A04:2025 · Casos y ejercicios hipotéticos

Propósito del módulo



Al finalizar, el participante podrá:

- Explicar el alcance de A03:2025 más allá de bibliotecas vulnerables.
- Inventariar y evaluar dependencias directas y transitivas.
- Identificar riesgos en repositorios, CI/CD, artefactos y proveedores.
- Reconocer fallas criptográficas y seleccionar controles.
- Proponer pruebas y remediaciones verificables.

APLICACIÓN / DISCUSIÓN

CASO HIPOTÉTICO · Plataforma de conciliación con bibliotecas externas y datos sensibles.

Qué significa cadena de suministro



El software llega por una secuencia de confianza

Desarrollador → repositorio → dependencias → compilación → artefacto → registro → despliegue

Cada transición puede introducir cambios, credenciales, configuraciones o código no confiable.

APLICACIÓN / DISCUSIÓN

Una imagen de contenedor puede heredar una biblioteca vulnerable.

Qué activos forman parte de la cadena



No se limita al archivo JAR

- Código fuente y repositorios.
- IDE, extensiones y estaciones de trabajo.
- Gestores y repositorios de paquetes.
- Servidores de compilación y CI/CD.
- Imágenes de contenedor y artefactos.
- Infraestructura como código y secretos.
- APIs, SaaS y servicios externos.

APLICACIÓN / DISCUSIÓN

Un token de publicación robado puede permitir subir una versión manipulada.

CWE relacionadas con A03



Debilidades representativas de 2025

- CWE-477 · Uso de función obsoleta.
- CWE-1104 · Componentes de terceros no mantenidos.
- CWE-1329 · Dependencia en componente no actualizable.
- CWE-1357 · Dependencia en componente insuficientemente confiable.
- CWE-1395 · Dependencia en componente de terceros vulnerable.

APLICACIÓN / DISCUSIÓN

La categoría agrupa causas relacionadas; no equivale a una sola CVE.

Fuentes oficiales y paquetes firmados



Reducir la incorporación de código alterado

- Obtener componentes de fuentes oficiales.
- Usar canales seguros.
- Verificar firmas y checksums disponibles.
- Fijar versiones deliberadamente.
- Evitar repositorios desconocidos y paquetes homónimos.
- Revisar procedencia antes de promover a producción.

APLICACIÓN / DISCUSIÓN

Una firma válida no demuestra ausencia de vulnerabilidades.

Despliegue escalonado y canario



Limitar el radio de impacto

- No actualizar todos los sistemas simultáneamente.
- Desplegar primero en grupo controlado.
- Observar métricas y comportamiento.
- Definir criterios para detener o revertir.
- Ampliar gradualmente.

Un proveedor confiable también puede ser comprometido.

APLICACIÓN / DISCUSIÓN

Liberar una versión primero a un servicio no crítico.

Ejemplo Maven: fijar versiones



Evitar rangos flotantes no controlados

Fragmento ilustrativo de pom.xml:

```
<dependency>
 <groupId>org.example</groupId>
 <artifactId>componente</artifactId>
 <version>2.4.1</version>
</dependency>
```

Revisar árbol de dependencias y documentar actualizaciones aprobadas.

APLICACIÓN / DISCUSIÓN

Coordenadas ficticias: validar versiones y avisos reales antes de adoptar.

Checklist de salida A03



Controles que deben poder demostrarse

- ☐ Dependencias directas y transitivas inventariadas.
- ☐ Fuentes confiables y versiones controladas.
- ☐ Mínimo privilegio y separación de funciones.
- ☐ Cambios auditados y actualizaciones basadas en riesgo.

APLICACIÓN / DISCUSIÓN

PREGUNTA · ¿Qué evidencia concreta demostraría cada control?